대외비(Confidential) · 본 문서는 샘플입니다

# 웹 애플리케이션 모의해킹 진단 결과 보고서

수행: **(주)비젼솔루션** | **종합 등급: 취약(개선 필요)**

| | | | |
|---|---|---|---|
| **진단 대상** | [고객사 사이트 URL] (워드프레스 기반) | **진단 기간** | 20XX-XX-XX ~ (1~2일) |
| **진단 유형** | 웹 애플리케이션 모의해킹 (블랙박스 기준) | **사용 도구** | OWASP ZAP · Nuclei |
| **점검 범위** | OWASP Top 10 기준 주요 항목(인젝션·인증·접근통제·보안설정·민감정보 노출 등) + 워드프레스 플러그인/테마/계정 취약점 | | |
| **진단 원칙** | 비파괴 — 시스템 변경·데이터 생성/삭제 없음. 사전 서면 동의 범위 내에서만 수행. | | |

※ 본 보고서는 **샘플**이며, 아래 발견 항목은 실제 워드프레스 진단에서 흔히 나오는 대표 유형을 예시로 구성한 것입니다. 실제 진단 시 귀사 사이트에서 발견된 항목만, 동일한 형식(근거·영향·조치)으로 작성해 드립니다.

## 1. 종합 결과

| 위험도 | 높음 | 중간 | 낮음 | 정보 | 합계 |
|---|---|---|---|---|---|
| 건수 | 1 | 6 | 5 | 다수 | 12 |

서버가 즉시 장악되는 치명적 취약점은 1건이며, 관리자 계정을 겨냥한 침입 위험을 높이는 중간 등급이 6건입니다. 특히 **구버전 플러그인 취약점 + 계정 이름 노출 + 로그인 보호 미흡**이 함께 존재하여, 공격자가 관리자 권한을 탈취할 경로가 열려 있습니다. 아래 우선순위대로 조치를 권고합니다.

## 2. 발견 항목 상세

### 높음 F-01. 알려진 취약점이 있는 구버전 플러그인

**근거** 설치된 파일 업로드 관련 플러그인이 공개된 취약점(CVE)이 존재하는 버전으로 확인되었습니다. `/wp-content/plugins/<plugin>/readme.txt`에서 버전을 식별했고, 해당 버전은 인증 없이 원격 코드 실행 또는 임의 파일 업로드가 가능한 것으로 보고된 버전입니다.

**영향** 공격자가 서버에 악성 스크립트를 올려 **사이트 전체와 서버를 장악**할 수 있습니다. 이 경우 고객 데이터 유출, 사이트 변조, 랜섬웨어 설치로 이어집니다.

**조치**

- 해당 플러그인을 **즉시 최신 버전으로 업데이트**(불가 시 비활성화·삭제)
- 코어·플러그인·테마 **자동 업데이트 활성화**
- 업로드 디렉터리(`/wp-content/uploads`)에서 PHP 등 실행 파일의 실행을 서버 설정으로 차단
- 조치 후 해당 경로에 웹셸이 남아 있지 않은지 점검

### 중간 F-02. SQL 인젝션 가능 지점

**근거** 검색·조회 파라미터에 `'`(작은따옴표) 등을 삽입했을 때 데이터베이스 오류 메시지가 응답에 노출되었습니다. 입력값이 검증 없이 쿼리에 들어가는 지점이 존재합니다.

**영향** 공격자가 쿼리를 조작해 **회원 정보·비밀번호 해시·주문 내역을 통째로 조회**하거나, 관리자 계정을 생성할 수 있습니다.

**조치**

- 모든 DB 접근을 **매개변수화 쿼리(Prepared Statement)** 또는 `$wpdb->prepare()`로 변경
- 입력값 서버단 검증(형식·길이·허용 문자 화이트리스트)
- DB 오류 메시지를 사용자에게 노출하지 않도록 `WP_DEBUG_DISPLAY` 비활성화
- 웹 방화벽(WAF)에 인젝션 차단 규칙 적용

### 중간 F-03. 반사형 크로스 사이트 스크립팅(XSS)

**근거** URL 파라미터로 전달한 스크립트가 응답 페이지에 그대로 출력되어 브라우저에서 실행되었습니다. 출력 시 이스케이프(인코딩)가 누락되어 있습니다.

**영향** 공격자가 악성 링크를 피해자에게 보내면, 피해자의 **로그인 세션(쿠키)을 탈취**하거나 관리자 화면에서 임의 작업을 실행시킬 수 있습니다.

**조치**

- 출력 시 `esc_html()`·`esc_attr()` 등 **맥락에 맞는 출력 인코딩** 적용
- Content-Security-Policy(CSP) 헤더로 인라인 스크립트 제한
- 입력값에서 HTML 태그 제거·정제(sanitize)

### 중간 F-04. 관리자 계정 이름 노출 (사용자 열거)

**근거** `/?author=1` 요청이 `/author/<아이디>`로 리다이렉트되어 관리자 로그인 ID가 노출됩니다. `/wp-json/wp/v2/users`와 `/feed/rdf`에서도 사용자 목록이 조회됩니다.

**영향** 로그인 ID가 공개되면 비밀번호만 알아내면 되므로, 자동화 도구로 비밀번호를 반복 시도하는 공격의 성공률이 크게 높아집니다.

**조치**

- REST API 사용자 목록을 비공개 처리(미사용 시 비활성화, 사용 시 인증 요청만 허용)
- `?author=` 아카이브 접근 차단 또는 리다이렉트 제거
- 로그인 ID와 화면 표시 이름(닉네임)을 분리 — 글 작성자에는 표시 이름만 노출

### 중간 F-05. XML-RPC 인터페이스 활성화

**근거** `/xmlrpc.php`가 열려 있고 `system.listMethods` 호출에 응답했습니다. 다중 인증 시도(`system.multicall`)가 가능합니다.

**영향** 한 번의 요청으로 수백 개 비밀번호를 시도하는 **무차별 대입 공격**과, 이를 이용한 DDoS 증폭에 악용됩니다.

**조치**

- XML-RPC를 사용하지 않으면 **완전 차단**(서버 설정 또는 플러그인)
- 사용이 필요하면 `system.multicall` 비활성화 + 접근 IP 제한 + 호출 속도 제한

### 중간 F-06. 상태 변경 요청에 CSRF 방어 부재

**근거** 일부 설정·요청 처리에서 CSRF 토큰(nonce)이 확인되지 않았습니다.

**영향** 로그인한 관리자가 공격 페이지를 열면, 본인도 모르게 **설정 변경·계정 생성 등**이 실행될 수 있습니다.

**조치**

- 상태를 바꾸는 모든 요청에 `wp_nonce_field()` / `check_admin_referer()` 적용
- 중요 쿠키에 `SameSite=Lax` 이상 설정

### 중간 F-07. 구버전 코어·플러그인 다수

**근거** 워드프레스 코어와 다수 플러그인이 최신이 아닌 버전으로 확인되었습니다(예: 코어 6.3.2 식별, 일부 플러그인 2~3개 메이저 뒤처짐).

**영향** 공개된 취약점이 누적되어 시간이 갈수록 침해 위험이 커집니다.

**조치**

- 코어·플러그인·테마 전체 최신화 후 자동 업데이트 설정
- 사용하지 않는 플러그인·테마는 비활성화가 아니라 **삭제**

### 낮음 F-08. 보안 HTTP 헤더 누락

**근거** `Content-Security-Policy`, `X-Frame-Options`, `X-Content-Type-Options`, `Strict-Transport-Security` 헤더가 설정되어 있지 않습니다.

**영향** 클릭재킹, MIME 스니핑, 다운그레이드 공격 등 방어선이 비어 있습니다.

**조치** 웹서버 또는 플러그인에서 `X-Frame-Options: SAMEORIGIN`, `X-Content-Type-Options: nosniff`, `Strict-Transport-Security`, 그리고 사이트에 맞는 `Content-Security-Policy`를 추가합니다.

### 낮음 F-09. CORS 설정 오류

**근거** 일부 응답에서 교차 출처 접근을 과도하게 허용하는 설정이 확인되었습니다.

**영향** 다른 사이트의 스크립트가 민감한 응답을 읽어갈 수 있습니다.

**조치** `Access-Control-Allow-Origin`을 꼭 필요한 도메인으로 제한하고, 자격 증명 허용(`credentials`)과 와일드카드(`*`)를 함께 쓰지 않습니다.

### 낮음 F-10. 쿠키 보안 속성 미설정

**근거** 세션 쿠키에 `HttpOnly`·`Secure`·`SameSite` 속성이 일부 누락되었습니다.

**영향** 스크립트를 통한 쿠키 탈취나 전송 구간 노출 위험이 있습니다.

**조치** 인증 쿠키에 `HttpOnly`, `Secure`(HTTPS), `SameSite=Lax` 이상을 설정합니다.

### 낮음 F-11. 서버·구성요소 버전 정보 노출

**근거** 응답 헤더와 페이지에서 `Server`, `X-Powered-By`, 워드프레스 버전(generator 메타·`wp-links-opml.php`)이 노출됩니다.

**영향** 공격자가 버전에 맞는 공개 취약점을 골라 공격을 준비하기 쉬워집니다.

**조치** 서버·프레임워크 버전 헤더를 숨기고, 워드프레스 generator 메타와 버전 노출 경로를 제거합니다.

### 낮음 F-12. 설정·백업 파일 및 디렉터리 노출

근거 `/readme.html`, `/license.txt`가 접근 가능하며, 백업 파일 추정 경로(`.zip`·`.sql`)와 디렉터리 목록이 일부 노출됩니다.

**영향** 백업 파일이 노출되면 소스코드·DB·설정이 통째로 유출될 수 있습니다.

**조치**

- 안내·설정 파일 및 백업 파일의 외부 접근 차단(웹서버 규칙)
- 디렉터리 목록 보기(Directory Listing) 비활성화
- 백업 파일은 웹 루트 밖에 보관

## 3. 조치 우선순위

**1순위(즉시)** F-01 취약 플러그인 업데이트 — 서버 장악 경로 차단
**2순위** F-02·F-03 인젝션/XSS 수정, F-04·F-05 계정 노출·로그인 보호 — 관리자 탈취 경로 차단
**3순위** F-06·F-07 CSRF·구버전 정리
**4순위** F-08~F-12 헤더·쿠키·정보 노출 등 설정 강화

## 4. 재점검(2차) 및 데이터 폐기 안내

조치 완료 후 **같은 항목을 다시 진단**하여 실제로 막혔는지 확인하고, 1차 대비 **해결/미해결 차이표**를 함께 제공합니다(서비스에 1회 포함). 진단 과정에서 수집한 모든 자료(스캔 원본·캡처·접속정보)는 **2차 재점검 완료 후 복구 불가능하게 완전 폐기**하며, 폐기 사실을 데이터 폐기 확인서로 발급합니다.

---

본 보고서는 진단 시점 기준이며, 이후 시스템 변경분은 별도 진단이 필요합니다. 자동 점검 결과는 오탐 제거 검토를 거쳐 작성되며, 진단 결과를 바탕으로 한 운영 책임은 이용자에게 귀속됩니다. · 수행: (주)비젼솔루션 · 문의 biztalktome@gmail.com